Day23_SecurityMisconfiguration

PART A — FUNDAMENTALS

1. What is Security Misconfiguration?
It occurs when a system, server, application has insecure settings that can expose it to unauthorized access or insecure settings.

2. Give three examples of security misconfiguration.
- Enabling debug mode in a production environment
- Allowing Public access to private storage cloud bucket.
- Leaving default username and password unchanged.

3. Why can default accounts be dangerous?
Default accounts may use publicly unknown username and passwords. Attackers can exploit them to gain unauthorized access if credentials are changed or not properly secured.

4. Why should unnecessary features and services be disabled?
Unnecessary features and services increase the attack surface of a system. Disabling them reduces potential entry points that attackers could exploit.

5. What is application hardening?
It is a process of improving application's security by disabling insecure settings, removing unnecessary features, strengthening security controls and apply updates.

6. What is a configuration baseline?
It is a approved set of secure settings and standard used to reference as a configure and maintain systems securely.

7. What is configuration drift?
Configuration drift occurs when a system's actual settings gradually change and become different from its approved configuration baseline, potentially introducing security vulnerabilities.

8. Why should production and development configurations be separated?
Development environments may contain debugging tools, test accounts, and detailed error messages. Separating them prevents these potentially unauthorized settings from being exposed in the production environment.

9. Why can verbose error messages create security risk?
Verbose error messages may reveal sensitive data such as database details, internal file paths, server configurations, or application code. Attackers could use this data to identify weaknesses of the system creates security risk.

10. Explain the Principle of Least Privilege in configuration.
The Principle of Least Privilege means giving users, applications, and services only the minimum permissions required to perform their tasks. This prevents the risk of unauthorized access and damage if an account or service is compromised.

Day23_SecurityMisconfiguration

PART B — WEB CONFIGURATION

11. What is Debug Mode?
It is a setting used during application development to help identifiers analyse and fix errors by displaying detailed data such as application's behaviour.

12. Why should debugging information not normally be exposed publicly in production?
Debugging Information should reveal sensitive data such as source code, internal file path, database information and server configurations. Attackers use such information such as identify and exploit vulnerabilities.

13. What are HTTP security headers?
Instructions sent by a web server to a browser to help protect web application against security threats and attacks.

14. What is the basic purpose of HSTS?
HSTS[HTTP Strict Transport Security] instruct browser to communicate with a website using HTTPs only, helps prevented insecure HTTP connections and downgrade attacks.

15. What is the basic purpose of X-Content-Type-Options: nosniff?
It tells browser not to guess or interpret a file's content type. Instead browser follows the declared Content-Type, helping prevent certain MIME-type sniffing attacks.

16. Does using security headers alone guarantee that a website is secure? Explain.
No, Security headers provide additional protection, but they cannot prevent every type of attack. A website needs authentication, authorization, input validation, regular updates, secure coding practices and other security controls.

PART C — CLOUD & SECRETS

17. Give one example of a cloud configuration mistake.
Making a private cloud storage bucket accessible, allowing unauthorized users to view or download confidential files.

18. Why should API keys and passwords not be publicly exposed?
API keys and passwords are sensitive credentials. If exposed publicly, attackers may use them to access systems, steal data, or perform unauthorized access.

19. Are environment variables automatically secure simply because they are environment variables? Explain.
No. Environment variables can still be exposed through insecure server configurations, application logs, error messages, or unauthorized access to the system. They must be properly protected.

20. Why should cloud permissions follow Least Privilege?
Cloud permissions should follow Least Privilege so that users and services receive only the access they need. This reduces the risk of unauthorized access, data exposure, and damage if an account is compromised.

Day23_SecurityMisconfiguration

PART D — CONFIGURATION REVIEW

Analyze this fictional production system:

Debug Mode: ON

HTTPS: ON

Default Admin Account: Enabled

Detailed Errors: Visible to Public

Unused Demo App: Installed

Logging: Enabled

Unused Service: Running

Answer:

1. Identify every unsafe configuration.

    - Debug Mode: ON – May expose sensitive debugging information.
    - Default Admin Account: Enabled – Attackers may exploit known default credentials.
    - Detailed Errors: Visible to Public – May reveal internal system details, database information, and file paths.
    - Unused Demo App: Installed – May contain unnecessary features or security vulnerabilities.
    - Unused Service: Running – Increases the system's attack surface.

2. Identify the settings that are not automatically a problem.

    - HTTPS: ON – Provides encrypted communication between the browser and server.
    - Logging: Enabled – Helps monitor activities, investigate incidents, and detect suspicious behaviour.

3. Give at least four hardening recommendations.

    - Disable Debug Mode in production.
    - Disable or remove default admin accounts and use strong, unique credentials.
    - Remove unused demo applications.
    - Configure secure logging and restrict access to log files.

Day23_SecurityMisconfiguration

4. Which OWASP Top 10:2025 category applies?
   A02:2025 – Security Misconfiguration.

5. Explain why.
   The production system contains several insecure settings, such as enabled debug mode, default admin accounts, publicly visible detailed errors, and unnecessary applications and services. These weaknesses can expose sensitive information and create opportunities for attackers to compromise the system.

PART E — MINI CASE

A fictional company stores internal documents in cloud storage.

The storage configuration accidentally allows public Internet access.

Answer:

1. What went wrong: The cloud storage was incorrectly configured to allow public Internet access instead of restricting access to authorized users.

2. Which OWASP category applies: A02:2025 – Security Misconfiguration.

3. What asset is at risk?
The company's internal documents and confidential business information stored in the cloud.

4. What could the impact be?
- Unauthorized access to confidential documents.
- Data leakage or theft.
- Possible legal or regulatory consequences.

5. Give a high-level defensive recommendation.
Configure cloud storage with private access by default. Apply the Principle of Least Privilege, grant access only to authorized users, enable appropriate access controls, and regularly audit cloud permissions to prevent accidental public exposure.